

《计算机网络应用综合实践》选题登记表

模块三：网络安全攻防实践（共计 140 个候选题目）

（一）安全协议分析（ 7 ）：

| 序 | 题目                                                 | 任务具体要求                                                                                                                                                                                                                                    | 难度  | 人数 | 学 号 | 姓 名 |
|---|----------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----|----|-----|-----|
| 1 | 利用WireShark监听工具抓取TCP会话连接的完整过程并分析比较与SSL会话的区别        | 使用抓包工具时，合理的顺序是应先在抓包工具中启动监听，然后再人为‘制造’生成所需的协议报文，这样才能完整抓取整个握手连接过程所发生的报文。本题特别要求须完整抓取TCP和SSL会话连接的三次握手和四次挥手过程所产生的全部报文，并逐一解析报文内容。报文抓取不完整的不能及格。                                                                                                   | 8-9 | 1  |     |     |
| 2 | 利用WireShark嗅探器抓取登录FTP服务器的过程并分析FTP主动连接和被动连接模式的区别    | 使用抓包工具时，合理的顺序是应先在抓包工具中启动监听，然后再人为‘制造’生成所需的协议报文，这样才能完整抓取整个握手连接过程所发生的报文。注意FTP协议在被动连接模式时会有PORT子命令。本题特别要求必须完整抓取FTP的主动模式和被动模式连接建立和登录验证过程所产生的全部报文，并逐一解析报文内容。报文抓取不完整的不能及格。                                                                        | 6-7 | 1  |     |     |
| 3 | 利用WireShark嗅探器抓取POP3邮件接收和SMTP邮件发送协议的完整通信过程并分析二者的区别 | 使用抓包工具时，合理的顺序是应先在抓包工具中启动监听，然后再人为‘制造’生成所需的协议报文，这样才能完整抓取整个握手连接过程所发生的报文。本题特别要求须完整抓取POP3和SMTP协议的登录验证、邮件收发过程所产生的全部报文，并逐一解析报文内容。报文抓取不完整的不能及格。                                                                                                   | 7-8 | 1  |     |     |
| 4 | 利用WireShark嗅探器抓取POP3和IMAP4邮件接收协议并分析比较二者的优劣*        | 注：IMAP4协议在用户使用收/发件箱、新建文件夹和草稿功能时始终保持客户端与邮箱服务器端更新同步，而POP3仅在客户端机内；IMAP4除了上述webmail的双向通信特色外，还提供邮件摘要预览多设备（如安卓手机）邮箱访问支持等功能。建议本题通过使用IMAP4的上述主要特色来观察所捕获的通信过程与POP3的差异。本题特别要求须完整抓取IMAP4和POP3会话过程所产生的全部报文，并逐一解析报文内容。                                 | 8-9 | 1  |     |     |
| 5 | 利用WireShark嗅探器抓取使用IE登录某注册网站的密码并分析比较其安全改进措施         | 使用抓包工具时，合理的顺序是应先在抓包工具中启动监听，然后再人为‘制造’生成所需的协议报文，这样才能完整抓取整个握手连接过程所发生的报文。本题特别要求须分别抓取口令文本框密码明文无任何安全保护措施、口令文本框密码明文方式配合页面随机校验码、口令文本框密码MD5加密保护、口令文本框密码MD5加密配合页面随机校验码等不同情形所产生的全部报文，并逐一解析报文内容。报文抓取不完整的不能及格。要求针对每种情形下攻击者获取页面口令的可能方法进行说明，并分析可改进的安全措施。 | 6-7 | 1  |     |     |
| 6 | 利用WireShark嗅探器抓取SSH和Telnet服务的数据包并分析比较其安全性          | 使用抓包工具时，合理的顺序是应先在抓包工具中启动监听，然后再人为‘制造’生成所需的协议报文，这样才能完整抓取整个握手连接过程所发生的报文。本题要求须完整抓取Telnet和SSH会话连接（三次握手和四次挥手）全过程所产生的全部报文，并逐一解析报文内容。报文抓取不完整的不能及格。                                                                                                | 7-8 | 1  |     |     |
| 7 | 利用WireShark嗅探器进行网络性能监视和统计分析                        | 注： 本题要求将WireShark的Statistics菜单功能（统计）的各个子菜单项进行操作说明，并分析统计图表数据所反映的当前网络状况。                                                                                                                                                                    | 6   | 1  |     |     |

（二）网络扫描器用法 / 信息收集 / 安全风险评估实践（24）：

| 序 | 题目                                    | 任务具体要求                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                               | 难度  | 人数 | 学 号 | 姓 名 |
|---|---------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----|----|-----|-----|
| 1 | 使用NetScan Tool Pro 2003工具实现攻击前的信息收集   | 注： NetScan Tool Pro 2003是Windows平台上非常重要的集成化的信息收集工具。下载地址： <a href="http://www.nwpsw.com">http://www.nwpsw.com</a> 或 <a href="http://www.netscantools.com">http://www.netscantools.com</a> 。该工具包含Active Discovery and Diagnostic(包括ARP Ping/ARP Scan/DHCP Server Discovery/Duplicate IP Scanner/Email Validate/Finger/SMB/Network Routing Visualizer/OS Finger/Packet Flooder/Packet Generator/Ping Scanner/Port Scanner/SMTP Server Tests/TrouteRoute)、Passive Discovery（包括Connetion Monitor/Packet Capture/Whois/DNS query）、DNS Tools(包括Dig/Zone Transfer/Default System DNS Tools/Advanced DNS Tools/)和Local Computer and General Info. Tools(包括本地ARP Cache/本地网卡或无线网卡的信息与诊断)等功能。本课题要求演示并录屏该工具的全部功能的详尽用法，缺失任何一项将被视为不及格，并且严禁演示操作结果为空。 | 6   | 1  |     |     |
| 2 | 使用VisualRoute网络路由节点回溯分析工具实现对攻击目标的地理定位 | 注： VisualRoute是非常著名的网络路由节点回溯分析工具，以在世界地图上显示连结路径的方式，让你知道当无法连上某些IP时的真正问题所在。VisualRoute将tracert、ping及Whois等功能集成为一个简单易用的GUI图形界面，用来分析互联网的连通性，并能够找到路由器或者服务器的地理位置。注意VisualRoute和其注册机都需要Java VM(Java 虚拟机)环境。安装时首先要用注册机移除掉服务器认证，然后生成有效的keyfile。注意在Window Vista/7系统中需要管理员权限才能完成破解过程。本题要求操作使用该工具的IP Location Reporting、Whois Lookups, Network Provider Reporting、OmniPath Multiple Path Discovery、NetVu Multiple Route Topology Graph、Tracert Tests from Visualware Servers、Continuous Connection Testing with Report History、Reverse Traces from Remote Desktops Help Resolve Customer Connectivity Problems这些主要功能。本课题要求演示并录屏该工具的上述功能的详尽用法，缺失任何一项将被视为不及格，并且严禁演示的操作结果均为空。                                                                        | 6   | 1  |     |     |
| 3 | 使用Superscan扫描工具实现秘密端口扫描               | 注： 端口扫描的主要目的是辨识目标机器开放了哪些TCP和UDP端口，确定哪些服务正在运行，它们的版本号，以便从中发现相应的服务或进程的漏洞，从而确定网络入侵的入口点。当然端口扫描最好不要被对方发现。秘密端口扫描技术包括TCP SYN半开扫描、FIN扫描、SYN+ACK 扫描、TCP XMAS 扫描、TCP Null 扫描等多种高级扫描方式。Superscan号称Windows系统下速度最快的扫描器，可以说是目前世界上最受黑客欢迎的扫描器，下载地址： <a href="http://www.webattack.com/get/superscan.shtml">http://www.webattack.com/get/superscan.shtml</a> 。本课题要求演示并录屏该工具所支持的全部秘密扫描功能的详尽用法，缺失任何一项将被视为不及格，并且严禁演示的操作结果均为空。                                                                                                                                                                                                                                                                                                                             | 6   | 1  |     |     |
| 4 | 使用Nmap扫描工具实现秘密端口扫描                    | 注： 端口扫描的主要目的是辨识目标机器开放了哪些TCP和UDP端口，确定哪些服务正在运行，它们的版本号，以便从中发现相应的服务或进程的漏洞，从而确定网络入侵的入口点。当然端口扫描最好不要被对方发现。秘密端口扫描技术包括TCP SYN半开扫描、FIN扫描、SYN+ACK 扫描、TCP XMAS 扫描、TCP Null 扫描等多种高级扫描方式。Nmap号称扫描器之王，可以说是目前世界上最受黑客欢迎的扫描器，下载地址： <a href="http://www.insecure.org/nmap">http://www.insecure.org/nmap</a> 。本课题要求演示并录屏该工具所支持的全部秘密端口扫描功能的详尽用法，缺失任何一项将被视为不及格，并且严禁演示的操作结果均为空。                                                                                                                                                                                                                                                                                                                                                                             | 7-8 | 1  |     |     |

|    |                                         |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                |     |   |  |  |
|----|-----------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----|---|--|--|
| 5  | 使用SSS扫描工具实现IOS系统漏洞扫描                    | 注：最早由俄罗斯程序员开发的SSS工具，使用了完整的系统安全分析算法（intellectual core，该算法已申请了专利），在系统漏洞扫描的速度和精度方面优势明显，此外，SSS不仅可以扫描Windows系列平台，如95/98/ME/NT/2000/XP/.NET，而且还可以应用在UNIX平台及其分支上，如Linux, FreeBSD, OpenBSD, Net BSD, Solaris。由于采用了独特的架构，SSS是世界上唯一可检测出思科，惠普及其他厂商的网络设备IOS系统漏洞的软件，而且它在所有的商用软件中，还是唯一能在每个系统中跟踪超过4000个审核的软件。SSS即Shadow Security Scanner，下载地址： <a href="http://www.safety-lab.com/en">http://www.safety-lab.com/en</a> 。本课题要求演示并录屏使用该工具对IOS系统扫描的全部功能的详尽用法，缺失任何一项将被视为不及格，并且严禁演示的操作结果均为空。                                                                                                                                                                       | 6   | 1 |  |  |
| 6  | 使用小榕流光工具进行目标系统的漏洞扫描和利用                  | 注：小榕流光Fluxay是一款入侵与扫描综合工具软件，最新版本是流光5.0，已于2009年停止更新。作者是国内顶尖黑客高手小榕，其详细信息可参见其主页 <a href="http://www.netxeyes.org">http://www.netxeyes.org</a> 。小榕的流光软件拥有强大的漏洞探测功能，包括对POP3/SMTP，FTP，HTTP，PROXY，SQL，IPC\$等服务漏洞的扫描。本题要求演示并录屏用小榕流光软件扫描出至少3种漏洞的目标主机（严禁扫描结果为空），并利用这些漏洞实施入侵攻击的实践过程。                                                                                                                                                                                                                                                                                                                                                                       | 7-8 | 1 |  |  |
| 7  | 使用CGI & Web Scanner工具对互联网上的Web服务器进行漏洞检测 | 注：由国内知名高手zer9设计的CGI & Web Scanner是一款特别针对动态网站交互技术的漏洞问题而开发的Web应用漏洞检测工具，如采用CGI、ASP、PHP、JSP等网站动态交互技术而开发的动态网页中存在的漏洞。CGI & Web Scanner可检测出203个已知的CGI漏洞，可通过HTTPD辨认服务器的类型，并提供Microsoft SQL Server DOS检测、Httpd Overflow检测、IIS Hack检测、ASP检测、DOT漏洞检测等功能，并且支持多线程扫描。本课题要求演示并录屏至少3种Web漏洞的检测功能的详尽用法，缺失任何一项将被视为不及格，并且严禁演示的操作结果均为空。                                                                                                                                                                                                                                                                                                                             | 6   | 1 |  |  |
| 8  | 使用CIS工具对本机系统进行安全风险评估                    | 注：CIS全称是Cerberus Internet Scanner，运行于Windows NT和2000下，主要用于对系统平台做出评估，指出存在的安全漏洞，并提供一些建议。CIS检测的漏洞包括：WWW服务、FTP服务、MS SQL SERVER、NETBIOS、注册表设置、NT服务、SMTP服务、POP3服务、RPC服务、端口映射、FINGER服务、DNS服务、客户端浏览器的安全性等。CIS最为引人注目的功能，要数其NetBIOS共享扫描。CIS能根据NetBIOS漏洞，做出有关系统资源信息、网络共享资源、用户名、工作组名和弱口令等方面的详细扫描和安全建议。下载地址： <a href="http://www.cerberus-infosec.co.uk">http://www.cerberus-infosec.co.uk</a> 。本课题要求演示并录屏该工具的全部功能的详尽用法，缺失任何一项将被视为不及格，并且严禁演示的操作结果均为空。                                                                                                                                                                                                       | 6   | 1 |  |  |
| 9  | 使用SecAnalyst对本机系统进行安全风险评估               | 注：SecAnalyst安全风险评估工具可扫描出系统基于进程和文件的安全隐患。本题要求演示并录屏该工具所支持的全部功能的详尽用法，缺失任何一项将被视为不及格，并且严禁演示的操作结果均为空。                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                 | 6   | 1 |  |  |
| 10 | 使用MBSA对本机系统进行安全风险评估                     | 注：微软公司设计的MBSA安全风险评估工具是一款基于Windows系统的综合扫描工具。本题要求演示并录屏该工具所支持的全部功能的详尽用法，缺失任何一项将被视为不及格，并且严禁演示的操作结果均为空。                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                             | 6   | 1 |  |  |
| 11 | 使用MSAT对本机系统进行安全风险评估                     | 注：MSAT安全风险评估工具是微软公司提供的一款免费工具，是为了帮助企业评估其当前的IT基础设施所存在的弱点。它可按优先级列出风险问题，并提供如何将该风险降到最低的具体指导。本题要求演示并录屏该工具所支持的全部功能的详尽用法，缺失任何一项将被视为不及格，并且严禁演示的操作结果均为空。                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                 | 6   | 1 |  |  |
| 12 | 使用X-Scan对本机系统进行漏洞检测和扫描评估                | 注：X-Scan是一款由安全焦点组织提供的完全免费、免安装注册的攻击扫描评估攻击。它采用多线程方式对特定IP地址段进行端口扫描和漏洞检测，支持插件功能。所扫描的漏洞包括远程系统类型及版本探测、远程服务探测、各种弱口令漏检测、服务漏洞检测等20多个大类。本题要求演示并录屏该工具所支持的全部功能的详尽用法，缺失任何一项将被视为不及格，并且严禁演示的操作结果均为空。                                                                                                                                                                                                                                                                                                                                                                                                                                                          | 6   | 1 |  |  |
| 13 | 使用SATAN或Saint进行漏洞检测和安全分析                | 注：来自乌克兰的SATAN（Security Administrator's Tool for Analyzing Networks，安全管理员网络分析工具）是一个具有Web界面的端口及漏洞扫描程序。它可被配置为对目标主机或网络进行轻型、中型或是大型检测。SATAN为UNIX系统设计，主要用C和Perl脚本语言编写，不过其版本更新已中止，Saint（ <a href="http://www.wwdsi.com/saint/">http://www.wwdsi.com/saint/</a> ）是SATAN基础上的一个更新版本，同样基于Web界面，比SATAN包含更多的新测试。本题要求演示并录屏该工具所支持的全部功能的详尽用法，缺失任何一项将被视为不及格，并且严禁演示的操作结果均为空。                                                                                                                                                                                                                                                                                      | 6   | 1 |  |  |
| 14 | 使用GFI LANguard进行内网安全扫描和监测               | 注：GFI LANguard Network Security Scanner 7.0 build 20051117 注册版（有破解keygen.exe）是天天安全网推荐使用的一款商业版网络安全扫描工具，许多领先企业都选择了GFI LANguard N.S.S来检测网络安全，如Daimler Chrysler、NATO、Siemens Comm.、EDS、United Overseas Bank Ltd、Virgin Mobile、Medical Research Council (UK)、Anglicare、KLM等。N.S.S可实现自动监测网络中所有的安全隐患。通过分析操作系统以及所运行的应用程序，监测是否有安全漏洞，防止被黑客利用。N.S.S可检查整个网络的IP地址，提供管理员所有系统的服务类型和级别，需要的安全补丁，已开放的共享和端口，开启的服务和应用程序，弱密码的用户和组等。检测完可生成HTML报告。该报告还可根据用户需求定制。N.S.S 包含完整的补丁管理，在对用户的网络进行检测后，N.S.S 可告知所有操作系统和应用程序需要安装的补丁信息。下载地址： <a href="http://www.gfi.com/lannetscan/">http://www.gfi.com/lannetscan/</a> 。本题要求演示并录屏该工具所支持的全部功能的详尽用法，缺失任何一项将被视为不及格，并且严禁演示的操作结果均为空。 | 6   | 1 |  |  |
| 15 | 使用ISS工具进行网络安全漏洞扫描与综合评估                  | 注：ISS（Internet Security Scanner，下载地址： <a href="http://www.iss.net">http://www.iss.net</a> ）最早是由Christopher Klaus在92年编写的一款开源扫描器工具，目前ISS已成为一款商业性质的漏洞扫描与综合评估工具。由ISS公司（安氏公司曾是市值上亿美元、生产无数安全产品的著名公司，现已被IBM收购）维护的X-Force数据库是目前较全面的漏洞信息数据库。该数据库是CVE兼容的，支持在Web页面上使用关键字进行数据库检索，检索到的漏洞记录包括漏洞描述、受影响平台、补救措施、风险等级、影响结果、报告时间、参考链接等信息。本题要求演示并录屏该工具所支持的全部功能的详尽用法，缺失任何一项将被视为不及格，并且严禁演示的操作结果均为空。                                                                                                                                                                                                                                                                  | 6   | 1 |  |  |
| 16 | 使用Nessus工具进行系统漏洞远程扫描与分析                 | 注：由17岁天才少年开发的基于UNIX的扫描利器Nessus（下载地址： <a href="http://www.nessus.org">http://www.nessus.org</a> ），被认为是目前全世界使用人数最多（有超过75000个组织在使用它）的系统漏洞远程扫描与分析软件。它可运行于几乎所有的UNIX平台之上，永久升级和免费提供多达11000种插件（但需要注册并接受EULA-acceptance---终端用户授权协议）。它支持远程或本地（已授权的）的安全检查，带有GTK（Linux下的一种图形界面）图形界面。该系统被设计为Client/Sever模式，服务器端负责进行安全检查，客户端用来配置管理服务器端。在服务器端采用了plug-in的体系，并内置了脚本语言编译器，允许用户加入执行特定功能的自定义插件，以支持更多更快速和更为复杂的安全检查。在Nessus中还采用了一个共享的信息接口，称之知识库，其中保存了用户以前执行过的检查结果。检查结果可以HTML、纯文本、LaTeX（一种文本文件格式）等几种格式保存。本题要求演示并录屏该工具所支持的全部功能的详尽用法，缺失任何一项将被视为不及格，并且严禁演示的操作结果均为空。                                                                                                      | 6   | 1 |  |  |
| 17 | 使用COPS软件进行本地主机系统漏洞的检测                   | 注：漏洞扫描器通常可分为两种类型，主机漏洞扫描器（Host Scanner）和网络漏洞扫描器（Network Scanner）。主机漏洞扫描器是指在系统本地运行并检测本地系统漏洞的程序，如著名的COPS、tripewire、tiger等自由软件；网络漏洞扫描器是指基于Internet远程检测目标网络和主机系统的漏洞，如SATAN、ISS、Nessus、X-SCAN、SSS、CIS、GFI LANguard和HoleScan等。COPS是一款常用的主机漏洞检测自由软件。本题要求演示并录屏该工具所支持的全部功能的详尽用法，缺失任何一项将被视为不及格，并且严禁演                                                                                                                                                                                                                                                                                                                                                      | 6   | 1 |  |  |



|    |                                  |                                                                                                                                                                                                                                                                                                         |     |   |  |  |
|----|----------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----|---|--|--|
|    |                                  | 示的操作结果均为空。                                                                                                                                                                                                                                                                                              |     |   |  |  |
| 18 | 使用tripewire软件进行本地主机系统漏洞的检测       | 注：漏洞扫描器通常可分为两种类型，主机漏洞扫描器（Host Scanner）和网络漏洞扫描器（Network Scanner）。主机漏洞扫描器是指在系统本地运行并检测本地系统漏洞的程序，如著名的COPS、tripewire、tiger等自由软件；网络漏洞扫描器是指基于Internet远程检测目标网络和主机系统的漏洞，如SATAN、ISS、Nessus、X-SCAN、SSS、CIS、GFILANguard和HoleScan等。tripewire是一款常用的主机漏洞检测自由软件。本题要求演示并录屏该工具所支持的全部功能的详尽用法，缺失任何一项将被视为不及格，并且严禁演示的操作结果均为空。 | 6   | 1 |  |  |
| 19 | 使用tiger软件进行本地主机系统漏洞的检测           | 注：漏洞扫描器通常可分为两种类型，主机漏洞扫描器（Host Scanner）和网络漏洞扫描器（Network Scanner）。主机漏洞扫描器是指在系统本地运行并检测本地系统漏洞的程序，如著名的COPS、tripewire、tiger等自由软件；网络漏洞扫描器是指基于Internet远程检测目标网络和主机系统的漏洞，如SATAN、ISS、Nessus、X-SCAN、SSS、CIS、GFILANguard和HoleScan等。tiger是一款常用的主机漏洞检测自由软件。本题要求演示并录屏该工具所支持的全部功能的详尽用法，缺失任何一项将被视为不及格，并且严禁演示的操作结果均为空。     | 6   | 1 |  |  |
| 20 | 使用Nmap工具通过TCP/IP协议栈指纹探测进行操作系统的辨识 | 注：目前OS探测主要分为利用系统旗标（Banner）信息、利用TCP/IP协议栈指纹和Web查点综合分析几种方法。每种又进一步细分为主动鉴别和被动鉴别方式。Nmap号称端口扫描器之王，也是最常用和好用的协议栈指纹探测工具之一。下载地址：http://www.insecure.org/nmap。本题要求演示并录屏该工具所支持的全部指纹探测功能的详尽用法，缺失任何一项将被视为不及格，并且严禁无任何探测结果的演示。                                                                                          | 6-7 | 1 |  |  |
| 21 | 使用Queso工具进行远程主机操作系统的探测           | 注：目前OS探测主要分为利用系统旗标（Banner）信息、利用TCP/IP协议栈指纹和Web查点综合分析几种方法。每种又进一步细分为主动鉴别和被动鉴别方式。Queso是最常用的OS探测工具之一，下载地址：http://www.apostols.org/projectz/queso。本题要求演示并录屏该工具所支持的全部探测功能的详尽用法，缺失任何一项将被视为不及格，并且严禁无任何探测结果的演示。                                                                                                  | 6-7 | 1 |  |  |
| 22 | 利用Siphon工具进行远程主机操作系统的探测          | 注：目前OS探测主要分为利用系统旗标（Banner）信息、利用TCP/IP协议栈指纹和Web查点综合分析几种方法。每种又进一步细分为主动鉴别和被动鉴别方式。Siphon是最常用的OS探测工具之一，下载地址：http://siphon.datanerds.net。本题要求演示并录屏该工具所支持的全部探测功能的详尽用法，缺失任何一项将被视为不及格，并且严禁无任何探测结果的演示。                                                                                                            | 6-7 | 1 |  |  |
| 23 | 利用Xprobe2进行远程主机操作系统的探测           | 注：目前OS探测主要分为利用系统旗标（Banner）信息、利用TCP/IP协议栈指纹和Web查点综合分析几种方法。每种又进一步细分为主动鉴别和被动鉴别方式。Xprobe2是最常用的OS探测工具之一，下载地址：http://down.heibai.net/扫描工具xprobe2.zip。本题要求演示并录屏该工具所支持的全部探测功能的详尽用法，缺失任何一项将被视为不及格，并且严禁无任何探测结果的演示。                                                                                                | 6-7 | 1 |  |  |
| 24 | 利用p0f进行远程主机操作系统的探测               | 注：目前OS探测主要分为利用系统旗标（Banner）信息、利用TCP/IP协议栈指纹和Web查点综合分析几种方法。每种又进一步细分为主动鉴别和被动鉴别方式。p0f是最常用的OS探测工具之一，下载地址：http://lcamtuf.core dump.cx/p0f3/。本题要求演示并录屏该工具所支持的全部探测功能的详尽用法，缺失任何一项将被视为不及格，并且严禁无任何探测结果的演示。                                                                                                         | 6-7 | 1 |  |  |

（三）网络嗅探器用法 / Wireless LAN 信息探测与监听（15）：

| 序  | 题目                                    | 任务具体要求                                                                                                                                                                                                                                                                                                                      | 难度  | 人数 | 学 号 | 姓 名 |
|----|---------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----|----|-----|-----|
| 1  | 网络嗅探器Netxray(NAI)的用法                  | 注：Netxray是Windows平台上由NAI出品的一款常用嗅探利器。本题要求演示其全部功能的详尽用法。                                                                                                                                                                                                                                                                       | 6-7 | 1  |     |     |
| 2  | 网络嗅探器IPtools的用法                       | 注：IPtools是Windows平台上的一款很流行和易用的嗅探利器。本题要求演示其全部功能的详尽用法。                                                                                                                                                                                                                                                                        | 6   |    |     |     |
| 3  | 网络嗅探器Windump的用法                       | 注：Windump是Windows平台上的一款常用嗅探利器。本题要求演示其全部功能的详尽用法。                                                                                                                                                                                                                                                                             | 6-7 | 1  |     |     |
| 4  | 网络嗅探器Packetboy的用法                     | 注：Packetboy是Windows平台上的一款常用嗅探利器。本题要求演示其全部功能的详尽用法。                                                                                                                                                                                                                                                                           | 6-7 | 1  |     |     |
| 5  | 网络嗅探器Net monitor的用法                   | 注：MS Net monitor是Windows平台上由微软公司自己开发的一款嗅探利器。本题要求演示其全部功能的详尽用法。                                                                                                                                                                                                                                                               | 6-7 | 1  |     |     |
| 6  | 网络嗅探器ArpSniffer的用法                    | 注：ArpSniffer是Windows平台上的一款嗅探利器。本题要求演示其全部功能的详尽用法。                                                                                                                                                                                                                                                                            | 6   | 1  |     |     |
| 7  | 网络嗅探器Snort的用法*                        | 注：Snort最早是Linux平台上符合GPL规范的一款非常有名的开源入侵检测系统项目。其中也包括了嗅探功能。Snort目前已有Windows平台的版本。本题要求演示其在Windows平台上的嗅探功能的详尽用法。                                                                                                                                                                                                                  | 8-9 | 1  |     |     |
| 8  | 网络嗅探器Dsniff的用法*                       | 注：Dsniff是功能十分强大的嗅探器+MITM攻击工具套件包，作者是Dub Song，早在1999年12月，Song以密歇根大学CITI研究室的成果为基础，开发了这个后来极具影响力的网络安全渗透测试包。最新版本是2001年3月发布的v2.4b1 Beta版。下载网址: http://monkey.org/~dugsong/dsniff/，在安装之前先要下载安装libnet。目前它支持OpenBSD、Linux、Solaris系统平台，在http://www.datanerds.net/~mike/dsniff.html上可得到其在Windows上运行的早期版本。本题要求演示Dsniff的纯粹被动的网络嗅探功能的详尽用法。 | 8-9 | 1  |     |     |
| 9  | 使用Kismet工具基于Windows平台实现WLAN探测和无线数据包抓取 | 注：Kismet是目前基于Linux/Unix平台的最好的WLAN探测+嗅探抓包+IDS功能的开源免费软件包了。目前它已有在Windows平台上的版本，但需要安装AirPcap支持。本题要求演示其在Windows平台上的WLAN探测和嗅探抓包功能的详尽用法。                                                                                                                                                                                           | 7-8 | 1  |     |     |
| 10 | 使用Omnipeek基于Windows平台实现WLAN探测和无线数据包抓取 | 注：Omnipeek是目前基于Windows平台的一款常用无线嗅探器工具。本题要求演示其在Windows平台上的WLAN探测和嗅探抓包功能的详尽用法。                                                                                                                                                                                                                                                 | 7-8 | 1  |     |     |
| 11 | 使用Kismet工具基于Linux平台实现WLAN探测和无线数据包抓取*  | 注：Kismet是目前基于Linux/Unix平台的最好的WLAN探测+嗅探抓包+IDS功能的开源免费软件包了。本题要求演示其在Linux平台上的WLAN探测和嗅探抓包功能的详尽用法。                                                                                                                                                                                                                                | 8-9 | 1  |     |     |
| 12 | 使用Wellenreiter工具基于Linux平台实现WLAN数据包抓取* | 注：Wellenreiter是目前基于Linux/Unix平台的一款常用无线嗅探器工具。本题要求演示其在Linux平台上的WLAN抓包功能的详尽用法。                                                                                                                                                                                                                                                 | 8-9 | 1  |     |     |

|    |                                        |                                                                                                                                                                                                                  |     |   |  |  |
|----|----------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----|---|--|--|
| 13 | 使用AirSnort工具基于Linux平台实现WLAN数据包抓取*      | 注： AirSnort是目前基于Linux/Unix平台的一款常用无线嗅探器工具。本题要求演示其在Linux平台上的WLAN抓包功能的详尽用法。                                                                                                                                         | 8-9 | 1 |  |  |
| 14 | 利用Aircrack-ng破解无线WEP密码                 | 注： Kali Linux是著名的攻击者专用Linux虚拟平台， 内置大量攻击及审计工具，涵盖窃取、端口扫描、缓冲区溢出、中间人攻击、密码爆破、无线攻击、VoIP攻击等。Aircrack-ng套件是其中专用于破解无线WEP和WPA-PSK加密的工具。本题目采用有合法客户端活动的情况下的破解方式，即在破解过程中合法客户端需保持网络活动。本题要求演示虚拟系统无线网卡配置、无线抓包、口令捕获及暴力破解等功能的详尽用法。 | 8   | 1 |  |  |
| 15 | 利用Kali Linux套件工具包破解无线WiFi密码(WPA/WPA2)* | 注： Kali Linux是著名的攻击者专用Linux虚拟平台（LiveCD）BackTrack的当前版本，是BackTrack改名后的升级套件包。本题要求演示在Kali中破解无线WPA-PSK密码的详细过程。                                                                                                        | 8-9 | 1 |  |  |

（四）网络隐身术 / 利用代理跳板工具的攻击（6）：

| 序 | 题目                                         | 任务具体要求                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                           | 难度   | 人数 | 学 号 | 姓 名 |
|---|--------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------|----|-----|-----|
| 1 | 利用开源项目Achilles实现Windows平台上的HTTP代理和MITM攻击*  | 注： Achilles下载地址： <a href="http://packetstormsecurity.nl/filedesc/achilles-0-27.zip.html">http://packetstormsecurity.nl/filedesc/achilles-0-27.zip.html</a> ，它运行在Windows平台，可拦截客户端浏览器和web服务器间任一方向的HTTP会话数据，并在转发前允许篡改这些数据包。                                                                                                                                                                                                                                                                                                         | 9-10 | 1  |     |     |
| 2 | 利用开源项目Spike Proxy实现Windows平台上的HTTP代理和字典攻击* | 注： 开放源码项目Spike Proxy是Spike应用程序测试套件（ <a href="http://www.immunitysec.com/spike.html">http://www.immunitysec.com/spike.html</a> ）的一部分（HTTP代理组件），可运行在Linux/BSD/Unix/Windows平台，功能包括自动SQL注入检测、Web网站爬行（Web Site Crawling）、登录表单暴力破解、字典穷举攻击检测、溢出检测和目录游走检测等。                                                                                                                                                                                                                                                                              | 9-10 | 1  |     |     |
| 3 | 利用开源项目Spike Proxy实现Linux平台上的HTTP代理和字典攻击*   | 注： 开放源码项目Spike Proxy是Spike应用程序测试套件（ <a href="http://www.immunitysec.com/spike.html">http://www.immunitysec.com/spike.html</a> ）的一部分（HTTP代理组件），可运行在Linux/BSD/Unix/Windows平台，功能包括自动SQL注入检测、Web网站爬行（Web Site Crawling）、登录表单暴力破解、字典穷举攻击检测、溢出检测和目录游走检测等。                                                                                                                                                                                                                                                                              | 9-10 | 1  |     |     |
| 4 | 利用Snake多级代理跳板工具实现SocksV5代理服务               | 注： 至少应配置实现代理IE/QQ/FoxMail这3种客户端应用程序的流量，并且至少是2级代理。<br>Snake代理跳板工具支持多达255级的Socks5代理服务，支持UDP包经由TCP进行隧道转发的功能，支持加密两个Snake代理之间的通信，功能十分强大，是突破某些封锁实现网上隐身的利器。使用Snake代理跳板，需要先在每一级跳板主机上安装Snake代理的服务器端程序（SkSockServer.exe），安装好启动服务后，自动打开默认的1813端口监听。在流量经过的多级代理跳板主机上，同样要分别安装SkSockServer.exe并启动Snake代理服务。Snake还支持在植入该服务端程序和安装启动之前，可设置多级代理服务器工作的相关选项参数，以及允许访问该代理的客户端IP地址及掩码信息。Snake的客户端可以是经过配置的普通的客户端应用软件，如IE浏览器、FTP命令或Telnet工具等，也可以使用Snake的客户端控制台主程序，只需在其中添加需要代理其流量的客户端应用程序标识项，如IE、QQ等，即可使这些应用程序通过Snake的多级代理方式，与真正的目标主机通信，从而隐藏真实的黑客所在主机的IP地址。 | 6-7  | 1  |     |     |
| 5 | 利用Snake代理跳板工具实现两个Snake代理节点之间的加密通信          |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                  | 6-7  | 1  |     |     |
| 6 | 清除攻击痕迹实践                                   | 注： 本题对日志文件清除工具软件不限，但要求仅篡改攻击者自身的记录信息。                                                                                                                                                                                                                                                                                                                                                                                                                                                                                             | 6-7  | 1  |     |     |

（五）入侵攻击术实践（56）：

| 序 | 题目                            | 任务具体要求                                                                                                                                                                                                                                                                                                                                                                                                       | 难度  | 人数 | 学 号 | 姓 名 |
|---|-------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----|----|-----|-----|
| 1 | Windows系统平台IPC\$攻击实践          | 注： 本题要求演示IPC\$攻击的完整过程（包括后门种植和利用）                                                                                                                                                                                                                                                                                                                                                                             | 6   | 1  |     |     |
| 2 | 利用操作系统漏洞及NC反向连接工具实施网络入侵攻击     | 注： 任务中涉及客户端（攻击方）、服务器端（目标靶机）需要分别配置的，两端的操作过程都要记录。                                                                                                                                                                                                                                                                                                                                                              | 6-7 | 1  |     |     |
| 3 | 利用L0phtCrack工具破解Windows系统账号口令 | 注： L0phtCrack是目前非常流行的一款Windows平台上的口令破解工具。本题要求实现暴力猜解和字典式猜解两种方式，以及结合pwdumpX工具获取SAM文件中所有账户的口令Hash值的过程，要求演示整个口令攻击过程，相关破解工具中的全部配置选项内容和功能菜单。                                                                                                                                                                                                                                                                       | 6   | 1  |     |     |
| 4 | 利用WMIcracker工具破解Windows系统账号口令 | 注： WMIcracker是目前常用的一款Windows平台破密工具。本题要求实现暴力猜解和字典式猜解两种方式，以及结合pwdumpX工具获取SAM文件中所有账户的口令Hash值的过程，要求演示整个口令攻击过程，相关破解工具中的全部配置选项内容和功能菜单。                                                                                                                                                                                                                                                                             | 6   | 1  |     |     |
| 5 | 利用SMBcracker工具破解Windows系统账号口令 | 注： SMBcracker是目前常用的一款Windows平台破密工具。本题要求实现暴力猜解和字典式猜解两种方式，以及结合pwdumpX工具获取SAM文件中所有账户的口令Hash值的过程，要求演示整个口令攻击过程，相关破解工具中的全部配置选项内容和功能菜单。                                                                                                                                                                                                                                                                             | 6   | 1  |     |     |
| 6 | 利用Cain工具破解Windows系统账号口令       | 注： Cain(暗黑之神)是目前很流行的一款功能非常强大的综合攻击工具。本题要求实现暴力猜解和字典式猜解两种方式，以及结合pwdumpX工具获取SAM文件中所有账户的口令Hash值的过程，要求演示整个口令攻击过程，相关破解工具中的全部配置选项内容和功能菜单。                                                                                                                                                                                                                                                                            | 6-7 | 1  |     |     |
| 7 | 利用ophcrack工具破解Windows系统账号口令   | 注： ophCrack是一款常用的快速Windows系统口令破密工具。本题需要结合pwdumpX工具获取SAM文件中所有账户的口令Hash值。要求演示整个口令攻击过程，以及该工具中的全部配置选项内容和功能菜单。                                                                                                                                                                                                                                                                                                    | 6   | 1  |     |     |
| 8 | 利用SAMInside工具破解Windows系统账号口令  | 注： SAMInside是目前很流行的一款功能非常强大的Windows系统破密工具。本题要求至少采用暴力猜解、字典猜解和掩码猜解3种方式进行LMHash和NTHash破解， 要求演示本地SAM文件被SYSKEY加密后的情形。以及导入不同格式的口令密文存储文件（如用pwdumpX工具获取的SAM文件中账户口令Hash值）的过程，要求演示整个口令攻击过程，相关破解工具中的全部配置选项内容和功能菜单。                                                                                                                                                                                                      | 6-7 | 1  |     |     |
| 9 | Linux系统账号口令的破解攻击实践*           | 注： 在Linux系统中口令存储在/etc/passwd或/etc/shadow文件中。本题对口令暴破工具软件不限，建议使用John the Ripper这一免费开源的快速系统口令破解工具软件。它可在已知密文的条件下暴力破解密码，支持目前大多数加密算法如DES/MD4/MD5等，支持包括Unix/Linux/Windows/DOS模式/BeOS/OpenVMS，常被黑客用于破解强度不足的Unix/Linux系列的系统root密码。目前版本为v1.7.3版，针对Windows的免费版为v1.7.0.1，可从其官方网站下载： <a href="http://www.openwall.com/john/">http://www.openwall.com/john/</a> 。本题要求分别测试口令在/etc/passwd和/etc/shadow中的两种情形下的暴力猜解和字典式猜解两种方式。 | 8-9 | 1  |     |     |



|    |                                                     |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                 |      |   |  |  |
|----|-----------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------|---|--|--|
| 10 | 针对漏洞网靶子站点的注入式攻击实践                                   | 注：本课题对注射工具软件不限。靶子站点使用指导老师提供的漏洞网靶子站点。要求分别演示爆库、爆表、爆字段（字段名/类型/宽度/字段值内容）等猜解过程。（漏洞网靶子站点要部署在本地）。                                                                                                                                                                                                                                                                                                                                                                                                      | 7-8  | 1 |  |  |
| 11 | XSS跨站脚本攻击实践                                         | XSS(Cross Site Script)跨站脚本攻击基于站点对用户提交的变量没有过滤或没有经过严格完整地HTML字符过滤就放到了数据库中，导致这些恶意提交的HTML代码被其他浏览该网站的用户访问时运行。被XSS攻击的后果可能是：敏感信息被泄露（如cookie被盗）；网站的浏览器用户被引导到其他恶意网站上甚至被挂马和被远程控制；借用合法浏览器用户的权限进行一些操作；借用合法用户实施DDoS攻击等。XSS的危害已使它成为Web攻击类型的前三甲。本课题要求能够利用XSS攻击盗取用户的cookies信息，以及能够在当前页面中插入另一站点的URL。工具和数据库不限。                                                                                                                                                                                                     | 7    | 1 |  |  |
| 12 | DvBBS论坛网站ASP木马攻击实践                                  | 注：本题要求先用X-Scan等扫描工具探测Web服务器是否具有.mdb数据库下载漏洞，然后使用MD5反向破解工具得到网站管理员的账户密码明文，然后登录论坛管理员的后台，上传后缀为.jpg的木马文件，并利用管理员后台主页中的数据库备份功能的漏洞，将备份数据库改为.asp木马。                                                                                                                                                                                                                                                                                                                                                       | 7-8  | 1 |  |  |
| 13 | 动易论坛网站ASP木马攻击实践                                     | 注：本题利用win2003存在的文件解析路径方面的一个漏洞，在动易2006论坛站点的新用户注册页面上故意填写一个以xxx.asp为会员名的新会员，然后利用画图工具生成一个新的图片asp脚本木马（利用火狐免杀大马webshell 8.0.asp），通过上传头像功能将木马上传后，打开上传的木马显示WebShell登录界面可获取shell。                                                                                                                                                                                                                                                                                                                        | 7-8  | 1 |  |  |
| 14 | 基于Windows系统平台编码实现缓冲区溢出攻击**                          | 注：本题要求自己编写溢出攻击的代码shellcode，具体使用工具不限。                                                                                                                                                                                                                                                                                                                                                                                                                                                            | 9-10 | 1 |  |  |
| 15 | 基于Linux系统平台编码实现缓冲区溢出攻击**                            | 注：本题要求自己编写溢出攻击的代码shellcode，具体使用工具不限。                                                                                                                                                                                                                                                                                                                                                                                                                                                            | 9-10 | 1 |  |  |
| 16 | 利用Cain工具实现结合ARP欺骗的DNS欺骗攻击**                         | 注：Cain(暗黑之神)是目前很流行的一款功能非常强大的综合攻击工具，包含嗅探、各种欺骗/中间人攻击、口令破解、路由协议分析等功能。本课题利用Cain的ARP—DNS欺骗功能，实现对用户请求解析的DNS域名给出欺骗性的应答IP地址，从而引导用户打开另一个网址。本题要求演示在正常的LAN内网（用户、网关、攻击者3个节点）环境中，利用CAIN实现ARP欺骗和ARP—DNS欺骗的过程和方法。                                                                                                                                                                                                                                                                                              | 7-8  | 1 |  |  |
| 17 | 利用Dsniff工具包实现针对SSH协议的MITM(Man-In-The-Middle)中间人攻击** | 注：Dsniff是功能十分强大的嗅探器+MITM攻击工具套件包，作者是Dub Song，早在1999年12月，Song以密歇根大学CITI研究室（Center for Information Technology Integration）的研究成果为基础，开发了这个后来具有很大影响力的网络安全渗透测试工具包。最新版本是2001年3月发布的v2.4b1 Beta版。下载网址： <a href="http://monkey.org/~dugsong/dsniff/">http://monkey.org/~dugsong/dsniff/</a> ，在安装之前先要下载安装libnet。目前它支持OpenBSD、Linux、Solaris系统平台，在 <a href="http://www.datanerds.net/~mike/dsniff.html">http://www.datanerds.net/~mike/dsniff.html</a> 上可得到其在Windows平台上运行的早期版本。本题要求演示Dsniff的sshmitm组件功能的详尽用法。 | 8-9  | 1 |  |  |
| 18 | 利用Dsniff工具包实现针对SSL协议的MITM(Man-In-The-Middle)中间人攻击** | 注：本题要求演示Dsniff的webmitm组件功能的详尽用法。                                                                                                                                                                                                                                                                                                                                                                                                                                                                | 8-9  | 1 |  |  |
| 19 | 利用Dsniff工具包实施DNS欺骗攻击**                              | 注：本题要求演示Dsniff的dnsspoof组件功能的详尽用法。                                                                                                                                                                                                                                                                                                                                                                                                                                                               | 7-8  | 1 |  |  |
| 20 | 利用Dsniff工具包实现对特定TCP会话连接的流量控制                        | 注：本题要求演示Dsniff的tcpkill、tcptnice等组件功能的详尽用法。                                                                                                                                                                                                                                                                                                                                                                                                                                                      | 7-8  | 1 |  |  |
| 21 | 利用Ettercap工具包实施交换LAN环境下的假消息攻击*                      | 注：Ettercap是一个非常著名的交换环境下的高级嗅探器套件工具（ <a href="http://ettercap.sourceforge.net">http://ettercap.sourceforge.net</a> ），号称嗅探器中的屠龙刀。事实上Ettercap的大部分特性与DSniff相似。它集嗅探、拦截和记录功能于一体，作者是Alberto Ornaghi和Marco Vallerio。Ettercap支持多种主动/被动的协议分析，具有数据插入/过滤/保持连接同步等功能，其最新版本还包括许多更为强大的功能，如伪造数据包，对SSH/SSL协议的会话劫持，被动探测OS指纹，端口扫描，以及对各种口令的采集等功能，并且支持插件方式的功能扩展机制。本题要求演示Ettercap的嗅探、假消息插入等组件功能的详尽用法。                                                                                                                   | 7-8  | 1 |  |  |
| 22 | 利用Ettercap工具包实施针对SSL HTTP的会话劫持攻击**                  | 注：本题要求演示Ettercap的会话劫持/中间人攻击组件的功能和详尽用法。                                                                                                                                                                                                                                                                                                                                                                                                                                                          | 7-9  | 1 |  |  |
| 23 | 利用SMTP协议实施伪造发送者的电子邮件欺骗攻击                            | 注：本题要求演示通过Telnet登录到目标主机（邮件服务器）的SMTP端口，直接用ASCII文本行命令方式伪造并发送一封邮件的欺骗过程。                                                                                                                                                                                                                                                                                                                                                                                                                            | 7-8  | 1 |  |  |
| 24 | 利用Trinoo工具实施UDP Flood拒绝服务攻击*                        | 注：本题要求演示该工具的安装、配置、各个组件功能的详尽用法。                                                                                                                                                                                                                                                                                                                                                                                                                                                                  | 6-7  | 1 |  |  |
| 25 | 利用fapi工具实施TCP SYN Flood拒绝服务攻击*                      | 注：本题要求演示该工具的安装、配置、各个组件功能的详尽用法。                                                                                                                                                                                                                                                                                                                                                                                                                                                                  | 6-7  | 1 |  |  |
| 26 | 利用Fuck_them工具ICMP Echo Flood拒绝服务攻击*                 | 注：本题要求演示该工具的安装、配置、各个组件功能的详尽用法。                                                                                                                                                                                                                                                                                                                                                                                                                                                                  | 6-7  | 1 |  |  |
| 27 | 利用Mstream工具实施TCP ACK Flood拒绝服务攻击*                   | 注：本题要求演示该工具的安装、配置、各个组件功能的详尽用法。                                                                                                                                                                                                                                                                                                                                                                                                                                                                  | 6-7  | 1 |  |  |
| 28 | 利用TFN工具实施TCP SYN Flood拒绝服务攻击*                       | 注：本题要求演示该工具的安装、配置、各个组件功能的详尽用法。                                                                                                                                                                                                                                                                                                                                                                                                                                                                  | 6-7  | 1 |  |  |
| 29 | 利用Stackeldraht_V4工具实施TCP/ICMP协议洪水攻击*                | 注：本题要求演示该工具的安装、配置、各个组件功能的详尽用法。                                                                                                                                                                                                                                                                                                                                                                                                                                                                  | 6-7  | 1 |  |  |
| 30 | 利用Shaft工具实施UDP Flood拒绝服务攻击*                         | 注：本题要求演示该工具的安装、配置、各个组件功能的详尽用法。                                                                                                                                                                                                                                                                                                                                                                                                                                                                  | 6-7  | 1 |  |  |
| 31 | 利用TFK2K工具实施Smurf（蓝精灵）攻击*                            | 注：本题要求演示该工具的安装、配置、各个组件功能的详尽用法。                                                                                                                                                                                                                                                                                                                                                                                                                                                                  | 6-7  | 1 |  |  |
| 32 | 利用Stackeldraht_v2.66工具TCP/IGMP协议洪水攻击*               | 注：本题要求演示该工具的安装、配置、各个组件功能的详尽用法。                                                                                                                                                                                                                                                                                                                                                                                                                                                                  | 6-7  | 1 |  |  |
| 33 | 利用Trinity V3工具实施TCP Fragment Flood拒绝服务攻击*           | 注：本题要求演示该工具的安装、配置、各个组件功能的详尽用法。                                                                                                                                                                                                                                                                                                                                                                                                                                                                  | 6-7  | 1 |  |  |
| 34 | 利用Omega V3工具实施UDP/ICMP协议洪水攻击*                       | 注：本题要求演示该工具的安装、配置、各个组件功能的详尽用法。                                                                                                                                                                                                                                                                                                                                                                                                                                                                  | 6-7  | 1 |  |  |
| 35 | 利用Omega V3工具实施TCP/IGMP协议洪水攻击*                       | 注：本题要求演示该工具的安装、配置、各个组件功能的详尽用法。                                                                                                                                                                                                                                                                                                                                                                                                                                                                  | 6-7  | 1 |  |  |
| 36 | 利用Hydra工具破解HTTP协议（爆破web登录口令）                        | 注：Hydra是 Kali 系统内置的一款由黑客组织THC开发的开源爆破工具，号称九头蛇。它是目前支持各种网络协议最多的口令爆破工具了，并且支持自定义的字典扩展机制。本题要求分别演示web登录页面为get和post两种提交方式下用hydra破解web登录口令的详尽用法。包括使用自定义的账号名字典和密码字典实施爆破的过程。                                                                                                                                                                                                                                                                                                                               | 8-9  | 1 |  |  |
| 37 | 利用Hydra工具破解HTTPS协议（爆破加密web登录页面口令）**                 | 注：本题要求分别演示web登录页面为get和post两种提交方式下用hydra破解加密web登录口令的详尽用法。包括使用自定义的用户名字典和密码字典实施爆破的过程。                                                                                                                                                                                                                                                                                                                                                                                                              | 9-10 | 1 |  |  |



|    |                                      |                                                                                                                                                                                                                                                                                                                                                                                                      |      |   |  |  |
|----|--------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------|---|--|--|
| 38 | 利用Hydra工具破解Http-proxy服务器的登录口令*       | 注：本题要求演示采用hydra针对基于http-proxy协议的Web代理服务器和反向代理服务器登录口令的爆破过程。包括使用自定义的用户名字典和密码字典实施爆破的过程。                                                                                                                                                                                                                                                                                                                 | 8-9  | 1 |  |  |
| 39 | 利用Hydra工具破解Sock5代理服务器的登录口令*          | 注：本题要求演示采用hydra针对Sock5代理服务器的登录口令的爆破过程。包括使用自定义的用户名字典和密码字典实施爆破的过程。                                                                                                                                                                                                                                                                                                                                     | 8-9  | 1 |  |  |
| 40 | 利用Hydra工具破解SMB协议的IPC\$连接登录口令         | 注：本题要求演示采用hydra针对微软小型网络NETBIOS的SMB服务（微软网络文件和打印机共享服务）的口令爆破过程。包括使用自定义的用户名字典和密码字典实施爆破的过程。                                                                                                                                                                                                                                                                                                               | 7-8  | 1 |  |  |
| 41 | 利用Hydra工具破解Telnet协议的登录口令             | 注：本题要求演示采用hydra针对远程登录服务器的telnet登录口令的爆破过程。包括使用自定义的用户名字典和密码字典实施爆破的过程。                                                                                                                                                                                                                                                                                                                                  | 7-8  | 1 |  |  |
| 42 | 利用Hydra工具破解RDP协议的远程桌面协助登录口令          | 注：本题要求演示采用hydra针对远程桌面协助服务RDP登录口令的爆破过程。包括使用自定义的用户名字典和密码字典实施爆破的过程。                                                                                                                                                                                                                                                                                                                                     | 7-8  | 1 |  |  |
| 43 | 利用Hydra工具破解SSH协议的登录口令                | 注：本题要求演示采用hydra针对SSH服务器的安全远程登录口令的爆破过程。包括使用自定义的用户名字典和密码字典实施爆破的过程。要求分别演示当SSH服务器采用v1和v2两种协议时的口令破解操作。                                                                                                                                                                                                                                                                                                    | 8-9  | 1 |  |  |
| 44 | 利用Hydra工具破解SQL Server数据库服务器的登录口令     | 注：本题要求演示采用hydra针对微软SQL-SERVER关系数据库服务器登录口令的爆破过程。包括用自定义的用户名字典和密码字典实施爆破的过程。                                                                                                                                                                                                                                                                                                                             | 8-9  | 1 |  |  |
| 45 | 利用Hydra工具破解MYSQL数据库服务器的登录口令          | 注：本题要求演示采用hydra针对MySQL关系数据库服务器登录口令的爆破过程。包括使用自定义的用户名字典和密码字典实施爆破的过程。                                                                                                                                                                                                                                                                                                                                   | 8-9  | 1 |  |  |
| 46 | 利用Hydra工具破解开源POSTGRES数据库服务器的登录口令*    | 注：本题要求演示采用hydra针对开源POSTGRES关系数据库服务器登录口令的爆破过程。包括使用自定义的用户名字典和密码字典实施爆破的过程。靶子POSTGRES数据库的OS系统平台不限（可基于Windows或Linux系统部署）。                                                                                                                                                                                                                                                                                 | 8-10 | 1 |  |  |
| 47 | 利用Hydra工具破解Oracle关系数据库服务器的登录口令*      | 注：本题要求演示采用hydra针对甲骨文公司的Oracle关系数据库服务器登录口令的爆破过程。包括使用自定义的用户名字典和密码字典实施爆破的过程。靶子Oracle数据库的OS系统平台不限（可基于Windows或Linux系统部署）。                                                                                                                                                                                                                                                                                 | 8-10 | 1 |  |  |
| 48 | 利用Hydra工具破解FTP文件传输服务器的登录口令           | 注：本题要求演示采用hydra针对文件传输服务器的FTP登录口令的爆破过程。包括使用自定义的用户名字典和密码字典实施爆破的过程。                                                                                                                                                                                                                                                                                                                                     | 7-8  | 1 |  |  |
| 49 | 利用Hydra工具破解PC Anywahre远程主机控制的登录口令    | 注：本题要求演示采用hydra针对PC Anywhere远程主机控制软件的服务器端的登录口令的爆破过程。包括使用自定义的用户名字典和密码字典实施爆破的过程。                                                                                                                                                                                                                                                                                                                       | 7-8  | 1 |  |  |
| 50 | 利用Hydra工具破解VNC远程主机控制的登录口令            | 注：本题要求演示采用hydra针对VNC远程主机控制软件的服务器端的登录口令爆破过程。包括使用自定义的用户名字典和密码字典实施爆破的过程。                                                                                                                                                                                                                                                                                                                                | 7-8  | 1 |  |  |
| 51 | 利用Hydra工具破解邮件服务器的登录口令                | 注：本题要求演示采用hydra针对电子邮件服务器的POP3/SMTP/IMAP4服务端口（分别对应接收邮件、外发邮件、远程邮件索引）的登录口令的爆破过程。包括使用自定义的用户名字典和密码字典实施爆破的过程。靶子邮件服务器的OS系统平台不限（可基于Windows或Linux系统部署）。                                                                                                                                                                                                                                                       | 8-10 | 1 |  |  |
| 52 | 利用Hydra工具破解无线WiFi路由器的Web登录口令         | 注：本题要求演示采用hydra针对无线路由器的web登录页面的口令爆破过程。包括使用Kali系统提供的各个wifi字典。                                                                                                                                                                                                                                                                                                                                         | 8-10 | 1 |  |  |
| 53 | 利用SQLMAP在本地DVWA上实践SQL注入攻击            | 注：本题要求在本机的vmware中，分别启动Kali虚拟机系统和已部署好DVWA靶子站点的2003系统，（也可以在自己的本机系统上安装python2. x/3. x IDE开发或运行时环境，作为SQL注入攻击的客户端运行SQLMAP软件），对在VMware中的虚拟机系统已部署的本地DVWA靶子站点实施SQL注入攻击。要求分别演示爆库、爆表、爆字段（字段名/类型/宽度/敏感字段的取值内容）等猜解过程。                                                                                                                                                                                            | 8-10 | 1 |  |  |
| 54 | 利用SQLMAP在本地SQLi-Labs上实践SQL注入攻击       | 注：本题要求在本机的vmware中，分别启动Kali虚拟机系统和已部署好DVWA靶子站点的2003系统，（也可以在自己的本机系统上安装python2. x/3. x IDE开发或运行时环境，作为SQL注入攻击的客户端运行SQLMAP软件），对在VMware中的虚拟机系统已部署的本地SQLi-Labs靶子站点实施SQL注入攻击。要求分别演示爆库、爆表、爆字段（字段名/类型/宽度/敏感字段的取值内容）等猜解过程。                                                                                                                                                                                       | 8-10 | 1 |  |  |
| 55 | 利用Burp Suite在必火官网SQLi-Labs上实践SQL注入攻击 | 注：本题要求使用Burp Suite（请点击 <a href="http://www.bihuoedu.com/vul/sqli/sqli_id.php">http://www.bihuoedu.com/vul/sqli/sqli_id.php</a> 首次访问时提示下载位置）提供的CTF工具包里的火狐渗透便携版工具，在必火官网上实践针对其已部署的SQLi-Labs靶子站点实施SQL注入攻击。要求分别演示爆库、爆表、爆字段（字段名/类型/宽度/敏感字段的取值内容）等猜解过程。                                                                                                                                                     | 8-9  | 1 |  |  |
| 56 | 基于Metasploit Framework套件实施反弹木马攻击     | 注：本题要求使用Kali Linux虚拟机系统内置的Metasploit套件，首先使用其msfvenom（毒液）生成一个反弹木马文件，然后选用可实现反弹TCP连接的某个payload（位于 windows/meterpreter/reverse_tcp下），配置反弹连接的各项参数，在能够成功建立反向连接后，在攻击端Kali Linux系统中执行shell 命令或者run vnc命令等实现远程控制对方主机等，如：用shell命令拿到对方shell（黑屏cmd命令窗口）后，执行你熟悉的黑屏DOS命令实施攻击（如用at命令给目标靶子机设置定时计划任务，用net user给对方系统种植隐藏账户，让其定时关机，让植入的其他代码运行，修改管理员账户密码，执行run vnc命令实施远程控制（类似于远程桌面协助功能）。本题要求演示从反弹木马连接建立到之后的其上的某种可能的攻击行为。 | 8-9  | 1 |  |  |

（六）网络操作系统（NOS）安全配置 / 关系数据库系统（DBMS）安全配置（6）：

| 序 | 题目                                         | 任务具体要求                                                                                                                                                                                                                   | 难度  | 人数 | 学 号 | 姓 名 |
|---|--------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----|----|-----|-----|
| 1 | 基于Windows平台的安全模板及组策略编辑工具实现多台服务器操作系统的安全配置同步 | 本题Windows平台环境可任选Windows2003/2008/2012/2016/2020…企业版（高级服务器版）之一。本题要求演示通过MMC管理控制台使用MS提供的“安全模板”和“安全配置和分析”管理单元，配置系统的7个方面安全选项：①帐户策略②本地策略③事件日志④受限制的组⑤系统服务⑥注册表⑦文件系统，并对配置结果使用“安全设置”扩展为“组策略”导入到多台PC机的本地安全策略中，从而实现操作系统安全配置信息快速同步一致。 | 6-8 | 1  |     |     |
| 2 | 基于Windows 平台的安全模板工具实现多台PC机操作系统安全配置信息的同步    | 注：本题要求演示通过MMC管理控制台使用“安全模板”和“安全配置和分析”管理单元，配置系统的各种安全选项，并将配置结果导入到多台PC机中，从而实现操作系统安全配置信息的快速同步一致。注意Win系统的家庭版未提供默认的安全模版，需要导入已有模版。                                                                                               | 6-7 | 1  |     |     |
| 3 | MS SQL Server 200X 数据库系统的安全配置              | 注：本题要求演示通过在SQL Server的企业管理器中的安全配置以增强DBMS系统的安全性：①通过SQL操作查找是否有不符合密码安全要求的帐户并实现安全的密码策略②采用安全的帐号策略（分角色/改认证模式/管理员帐号的处理）③在查询分析器中管理系统内置的存储过程                                                                                      | 7-8 | 1  |     |     |

|   |                                 |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                      |      |   |  |  |
|---|---------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------|---|--|--|
|   |                                 | xp_cmdshell (要求演示xp_cmdshell+cmd窗口中的ipc\$相关命令)④数据库备份还原操作⑤审计日志查看及管理(清空/截断/压缩/C2审核功能)。                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                 |      |   |  |  |
| 4 | MySQL数据库系统的安全配置                 | 注：本题要求演示通过在MySQL命令窗口的安全配置以增强DBMS系统的安全性：①实现安全的密码策略②查看User表并删除空用户，实施安全的帐号策略（授权表的维护）③数据库备份还原操作④审计日志查看及管理（二进制日志的转换/利用日志恢复数据/慢日志性能分析）。                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                    | 6-7  | 1 |  |  |
| 5 | 基于Windows平台配置实现操作系统的网络安全与性能优化配置 | 本题Windows平台不限。本题要求至少实现对系统如下的12个模块的安全配置项进行修改设置和性能优化建议：<br>（1）、如何对Windows系统的帐号和口令加固安全？（在安全模板中定制修改账户策略如密码策略、账户锁定策略、审核策略、用户权限分配、安全选项、安全模板中的受限制的组、在计算机管理（或net user命令）中禁用管理员账户或添加陷阱账户等）<br>（2）、在Windows系统中如何实现最少端口开启策略？如：关闭本机不用的不必要打开的端口，停止不用的服务？（定制安全模板中的系统服务、通过注册表编辑器定制限制开机自动启动的进程等）<br>（3）、如何及时打漏洞补丁？采用怎样的漏洞扫描工具检测操作系统及其上所安装的应用程序的各种漏洞？（具体的经典扫漏挖洞工具不限）<br>（4）、怎样做才能够及时使用病毒/木马查杀工具清除系统上的各种恶意代码？即：如何防范恶代类攻击？（如：修改浏览器的Internet选项以防范页面脚本代码类攻击；防范U盘病毒类移动介质使用带来的安全风险等）<br>（5）、如何按照开放最少资源、赋予最小权限的原则实施严格的账户权限管理和网络访问控制策略？（如：XX账户对YY资源的权限如何收紧？考虑通过注册表编辑或安全模板中的用户权限分配等途径进行ACL和ECL方面的增强配置）<br>（6）、如何修改网络服务相关配置文件中的参数，提高本机预防和抵御DDoS攻击的能力？（总结win系统的TCP/IP协议栈中涉及DDoS的注册表键值，修改之以优化对DDoS攻击的抵御能力）<br>（7）、如何利用Windows系统内置的防火墙组件和IP安全策略编辑器合理配置网络防火墙规则？（二者之一必做）<br>（8）、如何利用NIDS入侵检测系统及时拉响入侵警报？（如何部署IDS系统使及时发现并报警入侵行为？推荐使用Snort的Win版本）<br>（9）、如何防范交换环境下的网络监听攻击？（若网络流量有人在用抓包工具监听，如何应对？如何防范ARP欺骗攻击？如何防范DNS欺骗攻击？如何识别内网中正在实时抓包监听的节点？（网络上哪台机器正在监听？）等等。<br>（10）、对系统文件如何确保其数据完整性？（文件的数字签名和文件完整性方面的检查。使用win系统的WFP功能（系统可执行文件.exe/.com/.dll的数字签名检查和文件完整性检查）<br>（11）、对系统中的重要文件和敏感数据如何实施安全加解密？（使用win系统的EFS功能或PGP软件）<br>（12）、从Windows系统的全生命周期保护考虑如何增强其安全性？（如装机、安装副本分发、升级、打补丁等全流程中有哪些安全风险） | 7-10 | 1 |  |  |
| 6 | 基于Linux平台配置实现操作系统的网络安全与性能优化配置   | 本题Linux平台环境可任选 RedHat Enterprise Linux(RHEL)/Fedora Linux/CentOS/SUSE Linux Enterprise Server (SLES)/openSUSE Linux/Arch Linux/Debian Linux/Ubuntu Linux/Mageia Linux/Gentoo Linux/SlackWare Linux 的企业版（服务器版）之一。本题要求至少实现对系统如下的12个模块默认的安全配置项进行修改设置和性能优化建议：<br>配置Linux系列操作系统以增强其安全性，请考虑下述12个方面的安全加固设置项目：<br>（1）、在Linux系统中如何对帐号和口令加固安全？如：如何开启对帐号的审计？如何增强口令强度？如何保护口令存储文件等？<br>（2）、在Linux系统中如何实现最少端口开启策略？如：关闭本机不用的不必要打开的端口，停止不用的服务？<br>（3）、如何及时打漏洞补丁？考虑采用怎样的漏洞扫描工具检测系统及其上所安装的应用程序的各种漏洞？<br>（4）、怎样做才能够及时使用病毒/木马查杀工具清除系统上的各种恶意代码？<br>（5）、如何利用OS提供的或其他第三方的安全/网管工具，按照开放最少资源、赋予最小权限的原则实施严格的账户权限管理和网络访问控制策略？（例如：XX账户对YY资源的权限如何收紧？）<br>（6）、如何修改网络服务相关配置文件中的参数，提高本机预防和抵御DDoS攻击的能力？<br>（7）、如何利用Linux系统内置的Iptables模块合理配置网络防火墙规则？<br>（8）、如何利用NIDS入侵检测系统及时拉响入侵警报？（在linux系统上如何部署snort规则使及时发现入侵并动态修改防火墙规则？）<br>（9）、如何防范交换环境下的网络监听攻击？（若网络流量有人在用抓包工具监听，如何应对？）<br>（10）、对系统文件如何确保其数据完整性？（文件的数字签名和文件完整性方面的检查）<br>（11）、对系统中的重要文件和敏感数据如何实施安全加解密？<br>（12）、从Linux系统的全生命周期保护考虑如何增强其安全性？（如装机过程、副本分发、升级过程、补丁过程等全流程中有哪些安全风险？）                                                                                                                                                        | 8-10 | 1 |  |  |

（七）防火墙(Firwwall)、入侵检测系统(IDS)、蜜罐蜜网、AAA服务、VPN 网关等网络安全防御技术应用（16）：

| 序 | 题目                                                         | 任务具体要求                                                                                                                                                                                                | 难度  | 人数 | 学 号 | 姓 名 |
|---|------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----|----|-----|-----|
| 1 | 基于Windows平台的IPsec机制（IPsecpol规则的创建与配置）实现服务器操作系统的网络安全与性能优化配置 | 本题Windows平台环境可任选Windows2003/2008/2012/2016/2020…企业版（高级服务器版）之一。本题要求演示通过MMC管理控制台在“本地安全策略”管理单元中创建并设置本机的“IP安全策略”管理，并将自定义IP安全策略文件通过“指派”激活并应用的过程。任务中涉及要从本机进行测试验证的，也要记录；本题要求至少定义并验证15条包过滤规则，网络性能优化配置至少完成20处。 | 6-7 | 1  |     |     |



|    |                                                 |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                |      |   |  |  |
|----|-------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------|---|--|--|
| 2  | 基于Windows 7/10平台的IPsec机制实现PC机操作系统的网络安全与性能优化配置   | 注：本题要求演示通过MMC管理控制台在“IP安全策略管理”、“IP安全策略监视”、“高级安全Windows防火墙”中自定义入站、出站及连接安全规则并将策略文件应用到其他PC机的过程。任务中涉及要从本机进行测试验证的，也要记录；本题要求至少定义并验证15条过滤规则，网络性能优化配置至少完成20处。                                                                                                                                                                                                                                                                                                                                                                                                           | 6-7  | 1 |  |  |
| 3  | 基于Linux平台的IPtables机制实现包过滤型防火墙                   | 本题Linux平台环境可任选 RedHat Enterprise Linux(RHEL)/Fedora Linux/CentOS/SUSE Linux Enterprise Server (SLES)/openSUSE Linux/Arch Linux/Debian Linux/Ubuntu Linux/Mageia Linux/Gentoo Linux/SlackWare Linux 的企业版（服务器版）之一。完成本任务前请先阅读指导老师提供的有关本Linux发行版的基本介绍。本题要求至少定义并验证5条针对不同协议的规则。                                                                                                                                                                                                                                                                                      | 7-8  | 1 |  |  |
| 4  | 利用开源SmoothWall项目配置实现应用代理型防火墙*                   | SmoothWall是免费开源网络防火墙项目。它同时支持ISDN/ADSL/Cable和多网卡等网络设备，基于Web界面的SmoothWall软件具有丰富的选项功能，可将它配置为一个应用代理服务器、DHCP服务器、跨区域的包转发服务器、提供动态DNS解析服务、SSH服务和时间服务等。作为代理服务器，它还支持如用户端认证、延迟池等高级选项。在SmoothWall中还可以通过第三方插件，将其扩展为入侵检测、防病毒等服务的提供者。目前在开源社区已基于SmoothWall开发出几十个插件，通过这些插件使得SmoothWall甚至达到了UTM的功能。注：本题要求利用开源SmoothWall工具至少配置实现对客户端Web/FTP/E-Mail/Telnet这4种应用的流量代理，演示在SmoothWall中应用代理服务的安装和配置的全部内容，包括相关的客户端的配置及测试操作。建议在本机Windows系统中利用Vmware虚拟机工具架设SmoothWall系统平台。SmoothWall默认的Web管理界面使用81端口访问，请从其官网获取更详尽的参考： <a href="http://www.smoothwall.org">http://www.smoothwall.org</a> 。 | 8-9  | 1 |  |  |
| 5  | 基于Windows平台配置实现AAA(RADIUS)服务器*                  | 本题Windows平台环境可任选Windows2003/2008/2012/2016/2020…企业版（高级服务器版）之一。若选用2003系统，则需使用其内置可选的“Internet验证服务”(IAS)组件实现RADIUS服务器端；若选用2008以上系统，则需使用其内置的“网络策略和访问服务”服务器角色组件实现。RADIUS远程认证客户端工具建议使用RadiusTest、NTRadPing或其他RADIUS协议免费测试客户端软件工具（可模拟交换机或NAS设备与Radius服务器进行AAA协议交互）。本题要求使用抓包工具对RADIUS协议认证交互过程进行监听，在项目成果报告中应对AAA服务的不同解决方案进行分析比较和优劣评估。                                                                                                                                                                                                                                   | 8-9  | 1 |  |  |
| 6  | 基于Linux平台配置实现AAA(RADIUS)服务器**                   | 本题Linux平台环境可任选 RedHat Enterprise Linux(RHEL)/Fedora Linux/CentOS/SUSE Linux Enterprise Server (SLES)/openSUSE Linux/Arch Linux/Debian Linux/Ubuntu Linux/Mageia Linux/Gentoo Linux/SlackWare Linux 的企业版（服务器版）之一。完成本任务前请先阅读指导老师提供的有关本Linux发行版的基本介绍。本题中RADIUS服务器端的实现方案不限，可使用freeradius+mysql或gnuRadius+mysql等方式，RADIUS远程认证客户端工具建议使用RadiusTest、NTRadPing或其他RADIUS协议免费测试客户端软件工具（可模拟交换机或NAS设备与Radius服务器进行AAA协议交互）。本题要求使用抓包工具对RADIUS协议认证交互过程进行监听，在项目成果报告中应对AAA服务的不同解决方案进行分析比较和优劣评估。                                                                                  | 9-10 | 1 |  |  |
| 7  | 基于Windows平台利用snort和mySQL数据库实现对网络入侵检测日志数据的挖掘分析** | 本题Windows平台环境可任选Windows2003/2008/2012/2016/2020…企业版（高级服务器版）之一。本课题拟利用MySQL关系数据库平台对结构化数据的强大分析和处理能力，将Snort的入侵检测审计日志文本自动转储至MySQL数据库中，借助DBMS系统平台及其SQL查询、第三方联机分析和数据挖掘工具，开展对攻击历史事件的事后分析和审计数据的深度挖掘，从而使IDS系统具备揣摩数据在一段较长时间内变化的能力，弥补其误报率、漏报率高的问题，提高snort系统的预警和判断精准度。                                                                                                                                                                                                                                                                                                      | 9-10 | 1 |  |  |
| 8  | 基于Linux平台利用snort和mySQL数据库实现对网络入侵检测日志数据的挖掘分析**   | 本题Linux平台环境可任选 RedHat Enterprise Linux(RHEL)/Fedora Linux/CentOS/SUSE Linux Enterprise Server (SLES)/openSUSE Linux/Arch Linux/Debian Linux/Ubuntu Linux/Mageia Linux/Gentoo Linux/SlackWare Linux 的企业版（服务器版）之一。本题拟综合利用Linux平台上的组件工具iptables+snort+mySQL，实现对snort网络入侵检测日志数据的事后挖掘分析。其中，可利用iptables防火墙组件定义包过滤规则，利用snort+mySQL实现对snort产生的审计日志自动插入MySQL数据库中，借助DBMS系统平台及其SQL查询、第三方联机分析和数据挖掘工具，开展对攻击历史事件的事后分析和审计数据的深度挖掘。                                                                                                                                             | 9-10 | 1 |  |  |
| 9  | 利用开源SmoothWall项目配置实现入侵检测系统*                     | SmoothWall是免费开源网络防火墙项目。它同时支持ISDN/ADSL/Cable和多网卡等网络设备，基于Web界面的SmoothWall软件具有丰富的选项功能，可将它配置为一个应用代理服务器、DHCP服务器、跨区域的包转发服务器、提供动态DNS解析服务、SSH服务和时间服务等。SmoothWall中还可以通过第三方插件，将其扩展为入侵检测、防病毒等服务的提供者。目前在开源社区已基于SmoothWall开发出几十个插件，通过这些插件使得SmoothWall甚至达到了UTM的功能。注：本题要求利用开源SmoothWall平台配置实现IDS功能，演示在SmoothWall中对snort规则定制配置的方法，包括相关的客户端的配置及测试操作。本题要求所实现的IDS系统，应至少能够对内网（绿区内主机）向外网（红区内的主机）发起的DDOS攻击流量能够检测并产生报警。建议在本机Windows系统中利用Vmware虚拟机工具架设SmoothWall系统平台。SmoothWall默认的Web管理界面使用81端口访问，请从其官网获取更详尽的参考： <a href="http://www.smoothwall.org">http://www.smoothwall.org</a> 。   | 8-9  | 1 |  |  |
| 10 | 利用开源SmoothWall项目配置实现IPsec VPN网关*                | SmoothWall是免费开源网络防火墙项目。它同时支持ISDN/ADSL/Cable和多网卡等网络设备，基于Web界面的SmoothWall软件具有丰富的选项功能，可将它配置为一个应用代理服务器、DHCP服务器、跨区域的包转发服务器、提供动态DNS解析服务、SSH服务和时间服务等。SmoothWall中还可以通过第三方插件，将其扩展为入侵检测、防病毒等服务的提供者。目前在开源社区已基于SmoothWall开发出几十个插件，通过这些插件使得SmoothWall甚至达到了UTM的功能。注：本题要求利用开源SmoothWall平台配置实现其作为IPsec VPN网关的功能，演示在SmoothWall中建立远程连接IPsec VPN网关的配置内容，包括相关的客户端的配置及测试操作。本题要求演示VPN网关在多个远程连接同时开启情况下的工作情况。建议在本机Windows系统中利用Vmware虚拟机工具架设SmoothWall系统平台。SmoothWall默认的Web管理界面使用81端口访问，请从其官网获取更详尽的参考： <a href="http://www.smoothwall.org">http://www.smoothwall.org</a> 。              | 8-9  | 1 |  |  |



|    |                                      |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |      |   |  |  |
|----|--------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------|---|--|--|
| 11 | 利用开源SmoothWall项目配置实现SSL VPN网关*       | SmoothWall是免费开源网络防火墙项目。它同时支持ISDN/ADSL/Cable和多网卡等网络设备， 基于Web界面的SmoothWall软件具有丰富的选项功能，可将它配置为一个应用代理服务器、DHCP服务器、跨区域的包转发服务器、提供动态DNS解析服务、SSH服务和时间服务等。SmoothWall中还可以通过第三方插件，将其扩展为入侵检测、防病毒等服务的提供者。目前在开源社区已基于SmoothWall开发出几十个插件，通过这些插件使得SmoothWall甚至达到了UTM的功能。注：本题要求基于开源SmoothWall平台通过利用OpenVPN生成的服务器证书，配置实现其作为SSL VPN网关的功能。要求演示在SmoothWall中建立远程连接SSL VPN网关的配置内容，包括相关的客户端的配置及测试操作。本题要求结合wireShark抓包工具捕获openVPN连接建立的会话交互过程所产生的报文并做分析。建议在本机Windows系统中利用Vmware虚拟机工具架设SmoothWall系统平台。SmoothWall默认的Web管理界面使用81端口访问，请从其官网获取更详尽的参考： <a href="http://www.smoothwall.org">http://www.smoothwall.org</a> 。                                                                                             | 8-9  | 1 |  |  |
| 12 | 利用SnortSam实现IDS与分布式防火墙系统的联动以防御内网攻击** | SnortSam是一款用于Snort与防火墙系统自动联动的工具。SnortSam支持众多平台上的防火墙工具，包括Linux平台内置的iptables。SnortSam包含2个部分，一个是部署在网络中IDS节点上的snort系统中的插件（fwsam选项）用来发送报警，另一个是部署在分布式防火墙节点上的代理程序，用来接收来自fwsam的报警并修改iptables规则，从而达到动态改变防火墙过滤规则（如实时阻塞某个IP地址）的作用。本课题难度偏高，需要选题者利用虚拟机工具虚拟出一台IDS虚拟机、2台防火墙虚拟机，在IDS一侧的Linux系统上需解压安装libpcap和pcre（一个Perl库，包含了perl兼容的正则表达式库，用于规则的匹配）工具，采用的snort版本不限。要求演示实现当内网有人用Nmap扫描工具发出TCP Xmas Tree扫描报文时，2台防火墙的iptables可自动封禁该IP。                                                                                                                                                                                                                                                                  | 9-10 | 1 |  |  |
| 13 | 利用SnortSam实现IDS与分布式防火墙系统的联动以防御外网攻击** | SnortSam是一款用于Snort与防火墙系统自动联动的工具。SnortSam支持众多平台上的防火墙工具，包括Linux平台内置的iptables。SnortSam包含2个部分，一个是部署在网络中IDS节点上的snort系统中的插件（fwsam选项）用来发送报警，另一个是部署在分布式防火墙节点上的代理程序，用来接收来自fwsam的报警并修改iptables规则，从而达到动态改变防火墙过滤规则（如实时阻塞某个IP地址）的作用。本课题难度偏高，需要选题者利用虚拟机工具虚拟出一台IDS虚拟机、2台防火墙虚拟机，在IDS一侧的Linux系统上需解压安装libpcap和pcre（一个Perl库，包含了perl兼容的正则表达式库，用于规则的匹配）工具，采用的snort版本不限。要求演示实现当内网有人用Nmap扫描工具发出TCP Xmas Tree扫描报文时，2台防火墙的iptables可自动封禁该IP。                                                                                                                                                                                                                                                                  | 9-10 | 1 |  |  |
| 14 | 基于Linux平台利用Snort开源项目配置实现蜜网网关***      | 本题Linux平台环境可任选 RedHat Enterprise Linux(RHEL)/Fedora Linux/CentOS/SUSE Linux Enterprise Server (SLES)/openSUSE Linux/Arch Linux/Debian Linux/Ubuntu Linux/Mageia Linux/Gentoo Linux/SlackWare Linux 的企业版（服务器版）之一。本题拟基于开源Snort项目包配置实现采用iptables+snort+sebek+swatch+mySQL方案的蜜网网关系统。其中，利用iptables防火墙组件配置包过滤规则，利用snort+mySQL实现对snort产生的审计日志自动插入MySQL数据库中，利用Sebek Web可浏览查询、分析保存在数据库中的攻击者行为信息（如shell操作记录、击键历史），利用swatch可实现自动从系统日志中提取那些满足管理员预设条件（感兴趣）的日志记录，并通过电子邮件、系统响铃等方式发送警报（Swatch支持单遍模式或读取尾部更新2种模式分析snort日志）。                                                                                                                                                                           | 9-10 | 1 |  |  |
| 15 | 基于Linux平台利用honeyd软件配置实现虚拟蜜罐**        | 本题Linux平台环境可任选 RedHat Enterprise Linux(RHEL)/Fedora Linux/CentOS/SUSE Linux Enterprise Server (SLES)/openSUSE Linux/Arch Linux/Debian Linux/Ubuntu Linux/Mageia Linux/Gentoo Linux/SlackWare Linux 的企业版（服务器版）之一。本题需要选题者利用虚拟机工具虚拟出一台IDS虚拟机系统、1台用honeyd实现的虚拟蜜罐系统。IDS节点基于Linux平台及开源Snort项目包，配置实现采用iptables+snort+mySQL+Acid方案的IDS系统。其中：利用iptables防火墙组件配置包过滤规则，利用snort+mySQL实现对snort产生的审计日志自动插入MySQL数据库中，利用Snort内置提供的Web管理界面Acid自动连接MySQL数据库并将库中的日志数据呈现在Web页面上，利用honeyd部署在Snort中的Arpd组件实现将攻击流量自动转入到虚拟蜜罐节点上。虚拟蜜罐节点系统用honeyd模拟出一个假的Windows系统，以诱捕记录攻击者所产生的各种流量。Honeyd是GNU GPL许可协议下发布的开源项目，它是一个蜜罐框架，可模拟出各种操作系统平台和相应网络服务，从而达到诱骗黑客的目的。在安装Honeyd软件之前，请首先要安装它的三个支持软件库：libdnet、libevent、libpcap。 | 9-10 | 1 |  |  |
| 16 | 利用HoneynetRoo配置实现基于Vmware的第三代虚拟蜜网**  | 本题Linux平台环境可任选 RedHat Enterprise Linux(RHEL)/Fedora Linux/CentOS/SUSE Linux Enterprise Server (SLES)/openSUSE Linux/Arch Linux/Debian Linux/Ubuntu Linux/Mageia Linux/Gentoo Linux/SlackWare Linux 的企业版（服务器版）之一。本题拟利用基于Linux平台的Gen3虚拟蜜网网关HoneynetRoo软件包，在该蜜网网关上实现iptables+snort+sebek+swatch+mySQL方案的入侵行为捕获和日志挖掘分析方案。其中，可利用iptables防火墙组件定义包过滤规则，利用snort+mySQL实现对snort产生的审计日志自动插入数据库中，利用Sebek Web可浏览查询、分析保存在数据库中的攻击者行为信息（如shell操作记录、击键历史），利用swatch可实现自动从系统日志中提取那些满足管理员预设条件（感兴趣）的日志记录，并通过电子邮件、系统响铃等方式发送警报（Swatch支持单遍模式或读取尾部更新2种模式分析snort日志）。                                                                                                                                          | 9-10 | 1 |  |  |

（八）加解密技术应用（5）：

| 序 | 题目                                        | 任务具体要求                                                                                                                                                                                                                                                                                                                                                                                                  | 难度  | 人数 | 学 号 | 姓 名 |
|---|-------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----|----|-----|-----|
| 1 | 基于MS SQL Server 2008 数据库管理系统实现单元级和数据库级加解密 | Microsoft SQL Server提供两个级别的加密：数据库级别和单元级别，两个都使用密钥管理层次结构。单元级加密自2005版推出，仅具一个密钥管理层次结构，使用该功能是手动调用系统内置的对称密码函数的方式。利用该功能可方便地对数据库表中的某些敏感字段的数据进行加解密保护。在2008版的SQL Server中还提供了TDE(透明数据加密)的新特性，它提供了对某个数据库和日志文件的实时加解密，因而这一功能主要由数据库引擎来实现的，对客户端用户完全透明。使用此功能对数据库进行库级加解密无需编写任何代码。注：本项目需要选题者在SQL Server 2008平台上自建一个信用卡用户表（含ID、姓名、信用卡细节等字段，其中信用卡细节字段的数据需要加密而其他字段无需保护）。数据库级别的加密通过创建证书的方式，需要执行一些简单的脚本启用和激活TDE。注意：TDE只加密在服务器上的 | 7-8 | 1  |     |     |

|   |                                          |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                           |     |   |  |  |
|---|------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----|---|--|--|
|   |                                          | 数据库和日志文件的内容，并不会在客户端或客户端与服务器间的传送时加密数据。                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |     |   |  |  |
| 2 | 基于Linux平台利用开源项目OpenSSH配置实现SSH服务器*        | 本题Linux平台环境可任选 RedHat Enterprise Linux(RHEL)/Fedora Linux/CentOS/SUSE Linux Enterprise Server (SLES)/openSUSE Linux/Arch Linux/Debian Linux/Ubuntu Linux/Mageia Linux/Gentoo Linux/SlackWare Linux 的企业版（服务器版）之一。开放源码项目OpenSSH是SSH（Secure SHell，替代Telnet、RSH协议的安全远程连接外壳）协议的免费开源实现，它可实现用安全加密的网络连接工具代替Telnet、FTP、RLOGIN、RSH、RCP等的工具。OpenSSH支持SSH协议的版本1.3/1.5和2.0，从OpenSSH版本2.9开始其默认支持的SSH协议是版本2，即支持RSA和DSA密钥，默认使用RSA密钥。通常服务器端使用私钥，将其公钥用于客户端对服务器的身份验证。SSH的连接过程大致是：本地客户端发送一个连接请求到远程的服务器端；服务器检查连接申请报文和IP后，发送自己的公钥给SSH客户端；本地客户端再将密钥发回给服务器端，安全连接即建立起来。SSH支持两种级别的安全验证：基于密码的和基于非对称密钥的方式。本题要求通过修改SSH配置文件(/etc/ssh/sshd_config)，分别实现客户端采用密码验证方式和RSA密钥验证方式登录SSH服务器，要求使用Wireshark抓包工具分别抓取两种验证方式认证连接过程中的SSH协议数据包，分析比较两种认证方式的具体认证过程和二者的差异、各自的优缺点。SSH客户端可采用本机Windows系统，SSH客户端工具可使用 putty.exe 和 puttygen.exe 等工具。                                           | 8-9 | 1 |  |  |
| 3 | 基于Windows平台的PGP软件在文件系统及邮件系统中的应用          | 本题Windows平台不限。本题要求演示利用PGP工具创建密钥（公钥/私钥）对，并用其进行文件和电子邮件加密并签名、解密及验证签名的操作过程，以及利用PGP创建与使用PGPdisk的操作过程。要求记录PGP的安装配置过程、密钥对的创建和信任操作，文件加解密、PGPdisk的创建与使用、集成OutlookExpress或Outlook、Foxmail邮件客户端工具实现安全电子邮件（加密并签名、解密及验证签名）的收发，以及相关邮件客户端工具的配置、测试验证过程。                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                   | 7-8 | 1 |  |  |
| 4 | 基于Windows平台的GnuPG软件在文件系统和邮件系统中的应用        | 本题Windows平台不限。GnuPG的全称是GNU Privacy Guard，又简称GPG，是一个以Gnu通用公共许可证释出的开源密码学应用工具软件包，可用来取代PGP。主要用于数据加解密和数字签名及验证操作。GPG官方网站：http://www.gnupg.org/，分Windows和Linux版本，Linux系统中通常自带GPG。GPG支持的公钥算法包括RSA/RSA-E/RSA-S/ELG-E/DSA；对称加密算法包括3DES/CAST5/BLOWFISH/AES/AES192/AES256/TWOFISH；散列函数保护MD5/SHA-1/RIPEMD160/SHA-256/SHA384/SHA512；支持的压缩格式包括不压缩/zip/zlib/bzip2等。本题要求演示利用GPG工具创建密钥（公钥/私钥）对，并用其进行文件和电子邮件加密并签名、解密及验证签名的操作过程。建议首先阅读参考其官方教程http://www.gnupg.org/howtos/ch/index.html。在Windows平台上可利用其GUI界面的Windows版本工具（如gpg4win-1.1.4.rar），客户端邮件收发工具建议使用Thunderbird.rar。ThurdBird邮件客户端需先导入enigmail-0.95.7-tb+sm.XPi插件并启用对OpenGPG的支持。本课题要求记录GPG的安装配置过程、密钥对的创建和签名信任操作，文件加解密、ThurdBird客户端电子邮件（加密并签名、解密及验证签名）的安全收发，以及相关邮件客户端工具的配置、测试验证过程。                                                                                                                        | 7-8 | 1 |  |  |
| 5 | 基于Linux平台利用GnuPG软件实现对文件及电子邮件的加解密和数字签名操作* | 本题Linux平台环境可任选 RedHat Enterprise Linux(RHEL)/Fedora Linux/CentOS/SUSE Linux Enterprise Server (SLES)/openSUSE Linux/Arch Linux/Debian Linux/Ubuntu Linux/Mageia Linux/Gentoo Linux/SlackWare Linux 的企业版（服务器版）之一。GnuPG的全称是GNU Privacy Guard，又简称GPG，是一个以Gnu通用公共许可证释出的开源密码学应用工具软件包，可用来取代PGP。主要用于数据加解密和数字签名及验证操作。GPG官方网站：http://www.gnupg.org/，分Windows和Linux版本，Linux系统中通常自带GPG。GPG支持的公钥算法包括RSA/RSA-E/RSA-S/ELG-E/DSA；对称加密算法包括3DES/CAST5/BLOWFISH/AES/AES192/AES256/TWOFISH；散列函数保护MD5/SHA-1/RIPEMD160/SHA-256/SHA384/SHA512；支持的压缩格式包括不压缩/zip/zlib/bzip2等。本题要求演示利用GPG工具创建密钥（公钥/私钥）对，并用其进行文件和电子邮件加密并签名、解密及验证签名的操作过程。在Linux平台上GPG命令的一般语法为：gpg [选项][文件名]。建议首先阅读参考其官方教程http://www.gnupg.org/howtos/ch/index.html。测试的客户端要求使用Linux系统内置的邮件UA（用户代理）工具如Eudora等。本课题要求记录GPG的安装配置过程、密钥对的创建和签名信任操作，文件加解密、客户端电子邮件（加密并签名、解密及验证签名）的安全收发，以及相关邮件客户端工具的配置、测试验证过程。 | 8-9 | 1 |  |  |

（九）多机容错 / 服务器群集技术（5）：

| 序 | 题目                                                                 | 任务具体要求                                                                                                                                                                                                                                                  | 难度   | 人数 | 学 号 | 姓 名 |
|---|--------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------|----|-----|-----|
| 1 | 利用网络克隆工具实现对实验室大量主机的系统维护                                            | 大量主机重复性装机对于网管员/系统管理员而言是一项头疼的维护工作。网管员可利用Ghost多播服务(Multicast Server)将硬盘或分区的映像文件克隆到LAN中的客户端，实现不拆机的快速网络硬盘分区克隆，从而能够减轻工作量。目前基于LAN的网络克隆流行工具包括：腾龙备份大师(高级智能企业版)、Norton Ghost、Acronis True Image等，本题不限使用的软件。                                                      | 7-8  | 1  |     |     |
| 2 | 利用MS WSUS配置实现局域网内PC操作系统的补丁自动分发                                     | 本题Windows平台环境可任选Windows2003/2008/2012/2016/2020…企业版（高级服务器版）之一。本题要求在服务器端安装并配置WSUS，实现自动下载并审批补丁功能，同时要求进行补丁分发客户端的设置和验证。                                                                                                                                     | 7-8  | 1  |     |     |
| 3 | 利用Windows系统的群集服务(MSCS)配置实现双节点容错服务器群集(Cluster) **                   | 本题Windows平台环境可任选Windows2003/2008/2012/2016/2020…企业版（高级服务器版）之一。本题需要阅读参考文献《网管员必读：服务器与数据存储++（第二版）》P302～307页的指导说明。需要利用VMware虚拟出内网两台通过心跳连接的win服务器系统作为容错群集双节点。要求演示当一个节点失效后另一个能够实现自动接管和故障返回。                                                                   | 9-10 | 1  |     |     |
| 4 | 利用基于Windows系统的双节点容错群集实现对MS SQL Server服务器的版本升级**                    | 本题Windows平台环境可任选Windows2003/2008/2012/2016/2020…企业版（高级服务器版）之一。本题需要阅读参考文献《网管员必读：服务器与数据存储++（第二版）》P287～289页的指导说明。需要首先利用VMware虚拟出两台通过心跳连接的win服务器系统构成的容错双机群集，并利用MSCS的故障有状态返回机制，在SQL服务器从节点2返回时实现版本平滑升级（在整个升级过程中无需中断网络用户对SQL数据库的访问）。                           | 9-10 | 1  |     |     |
| 5 | 基于Linux平台配置实现LVS(Linux Virtual Server)-NAT方式的Apache Web服务器负载均衡集群** | 本题Linux平台环境可任选 RedHat Enterprise Linux(RHEL)/Fedora Linux/CentOS/SUSE Linux Enterprise Server (SLES)/openSUSE Linux/Arch Linux/Debian Linux/Ubuntu Linux/Mageia Linux/Gentoo Linux/SlackWare Linux 的企业版（服务器版）之一。本题需要阅读参考网上有关Apache Web服务器负载均衡集群的相关技术文章。 | 9-10 | 1  |     |     |